

EDGEZEN LABS — SECURITY ASSESSMENT

Briktra Vulnerability Report

Version 1.0.0 | 2026-08-10 | PROD | CONFIDENTIAL

VERDICT: NO-GO (Multi-role security)

1. Executive Summary

An authorized security assessment was performed covering role escalation, JWT/session handling, direct URL / broken access control, mass assignment, unauthorized APIs, security headers, upload surface discovery, and residual CSRF/XSS/SQLi risk. Active SQL injection and XSS exploit payloads were not sent to remote endpoints (safety policy); those areas are covered via headers review, architecture notes, and recommended staging tests.

Overall security verdict: FAIL / NO-GO for multi-role production hardening.

2. Scope & Methodology

In scope

- Role Escalation
- JWT Manipulation (malformed / empty / truncated rejection)
- Direct URL Access (UI deep-links — from committed role QA)
- Broken Access Control
- Mass Assignment
- Session Hijacking (post-logout token reuse)
- Expired Token / refresh lifecycle
- Unauthorized APIs
- SQL Injection *(policy: no remote exploit payloads)*
- XSS *(CSP/header review; no remote payloads)*
- CSRF *(Bearer vs cookie analysis)*
- File Upload Validation *(endpoint discovery only; no malicious files)*

Out of scope / limits

- No SQLi/XSS/RCE exploit payloads against PROD
- No forged HS256 JWTs (requires signing secret)
- Module APIs require `X-Request-Signature`; unsigned probes cannot fully prove API RBAC — **Flutter-signed UI sessions from role QA remain authoritative for BAC**
- Backend source not in this repo (Flutter web client + marketing site only)

Evidence sources

1. `scripts/security-probe.mjs` | `docs/QA/security/security-probe-results.json`
2. Role regressions: Tenant / Manager / Supervisor / Employee (`docs/qa-\*-regression/`)
3. Consolidated catalog: `docs/QA/assets/master-issues.json`
4. Prior: `docs/QA\_AUTH\_SECURITY\_AUDIT\_REPORT.md`

3. Attack Category Results

3.1 Role Escalation — **FAIL (Critical)**

Root cause: Client route guards missing or incomplete; server RBAC incomplete for signed Flutter clients (prior QA: employee received HTTP 200 for `/bills`, `/admin/plan-config`, `/users?role=tenant\_admin`).

CVSS-style rating: Critical (privilege exposure across tenants/admin functions).

3.2 JWT Manipulation — **PASS (malformed)** / **REVIEW (design)**

Design risk: `role` is embedded in the access JWT. If any API trusts the JWT `role` claim without re-checking the datastore, compromise of the HS256 secret enables trivial privilege escalation. Prefer server-side role lookup per request for sensitive operations.

Not executed: `alg=none` / signed role-forged tokens (exploit PoC policy + secret unknown).

3.3 Direct URL Access — **FAIL (Critical)**

Deep-link tests (Playwright, signed session) confirm restricted hashes remain reachable for non-admin roles. See EMP/MGR/SUP ISSUE catalogs and `docs/QA/Briktra\_Release\_Readiness\_Report.pdf`.

Unauthenticated deep-link to `#/employeeAttendanceTap` after logout showed feature/paywall shell rather than forced Login in employee recheck — session/route guard gap.

3.4 Broken Access Control — **FAIL (Critical)**

Positive control: `GET /tenants` returns 403 for non-privileged roles when called from signed UI.

3.5 Mass Assignment — **PASS*** (limited)

Residual risk: Without signature bypass or secret, elevation via user update could not be fully proven. Recommend explicit server deny + field allowlist tests in staging with valid signatures.

3.6 Session Hijacking / Logout — ****FAIL (High)**** + partial mitigation

Impact: Anyone holding a stolen access token remains authorized for up to ~24h after the user logs out (until natural expiry), even though refresh rotation is blocked.

3.7 Expired Token — ****REVIEW****

- Tokens include `exp` / `iat`; malformed tokens rejected.
- Full “wait until exp” soak not run in this window.
- Recommend automated test: freeze clock / use aged token fixture in staging to assert 401.

3.8 Unauthorized APIs — ****PASS**** (no token)

All sampled protected GETs without Authorization returned 401:

3.9 SQL Injection — ****SKIPPED**** (policy)

No ``OR 1=1` / union payloads sent to PROD.

Recommendation: Staging DAST + confirm parameterized queries/ORM on login, search, filters, and report endpoints.

3.10 XSS — ****FAIL (headers)**** / ****SKIPPED (payloads)****

Impact: Successful XSS (e.g., stored in notes/bills/profile) could read tokens from web storage and hijack sessions. Missing CSP removes a key browser mitigation.

3.11 CSRF — ****REVIEW (Low residual)****

Primary API auth uses `Authorization: Bearer` (Flutter). Classic cookie CSRF risk is reduced for those calls.

Verify no cookie-only mutation endpoints exist; keep CORS tight (API `Access-Control-Allow-Origin` not observed as `` in probe response headers).

3.12 File Upload Validation — ****REVIEW****

Probes to `/documents/upload`, `/upload`, `/files`, `/media/upload` with JSON body (no malware file) returned 401 Missing X-Request-Signature.

Upload security (type, size, magic bytes, malware scan, authz) not validated end-to-end. Document Wallet UI exists for roles — complete upload abuse testing in staging with signed requests.

3.13 Additional: Account Enumeration — ****REVIEW (Low)****

May allow username probing. Prefer uniform responses for unknown accounts.

4. Vulnerability Register

5. Risk Rating Summary

Security score (PROD multi-role): 3 / 10

6. Remediation Priority

1. P0 — Server RBAC: Enforce role checks on every sensitive route/method; do not rely on Flutter navigation.
2. P0 — UI route guards: Block createTenant, tenantAdmins, superAdmin, plans, company-details, reports (employee), etc.
3. P1 — Logout: Blacklist/revoke access JWT (or shrink TTL to minutes + rotate).
4. P1 — Post-logout routing: Always redirect unauthenticated deep links to Login.
5. P1 — Security headers: CSP, `frame-ancestors`, `X-Frame-Options`, `nosniff`, Referrer-Policy on `briktra.com/app`.
6. P2 — JWT: Prefer opaque access tokens or minimize claims; always authorize from DB role.
7. P2 — Hint enumeration: Constant-time / uniform hint responses.
8. P2 — Upload: Signed-request E2E validation suite in staging.
9. P2 — Staging DAST: SQLi + XSS suite before next release candidate.

7. Tools & Artifacts

Re-run:

```
node scripts/security-probe.mjs
```

8. Sign-off

Revision: 1.0.0 — 2026-08-10 — Initial PROD security assessment (authorized, no exploit payloads).

